

Güvenlik Operasyon Merkezi (SOC) Teknolojileri: Kapsamlı Bir Bakış

Yönetici Özeti

Bu brifing, modern bir Güvenlik Operasyon Merkezi'nin (SOC) temelini oluşturan kritik teknolojileri ve bunların birbirleriyle olan ilişkilerini sentezlemektedir. Analiz, dört ana teknoloji sütununa odaklanmaktadır: Güvenlik Bilgi ve Olay Yönetimi (SIEM), Uç Nokta Tespiti ve Müdahale (EDR), Güvenlik Orkestrasyonu, Otomasyonu ve Müdahale (SOAR) ve Elastic Stack gibi veri analizi platformları. Temel çıkarım, siber güvenliğin, geleneksel antivirüs gibi temel koruma mekanizmalarından, EDR'in sağladığı derinlemesine uç nokta görünürlüğüne, SIEM'in sunduğu merkezi log korelasyonuna ve SOAR'ın getirdiği verimlilik ve otomasyona dayalı, entegre ve çok katmanlı bir savunma stratejisine evrildiğidir. Kuruluşlar, artan tehdit karmaşıklığı, uyarı yorgunluğu ve uzaktan çalışma gibi zorluklarla başa çıkmak için bu araçları bir araya getirmektedir. EDR, uç noktalarda gelişmiş tehditleri tespit edip müdahale ederken, SIEM ve Elastic Stack, ağ genelindeki tüm log kaynaklarından gelen verileri birleştirerek bütünsel bir görünüm sunar. SOAR ise bu araçları tek bir arayüzde birleştirerek, manuel süreçleri otomatik hale getirir ve analistlerin daha stratejik görevlere odaklanmasını sağlar.

1. Güvenlik Bilgi ve Olay Yönetimi (SIEM)

SIEM, bir SOC analistinin kullandığı temel güvenlik çözümüdür. Temel işlevi, bir ağdaki çok sayıda ve farklı türdeki log kaynağından gelen verileri merkezi bir konumda toplamak, standartlaştırmak, ilişkilendirmek (korelasyon) ve önceden tanımlanmış kurallar aracılığıyla kötü niyetli faaliyetleri tespit etmektir.

Temel İşlevi ve Amacı

SIEM çözümleri, bir organizasyonun teknoloji altyapısındaki tüm cihazlardan, sunuculardan ve uygulamalardan gelen log verilerini toplayarak siber tehditlere karşı bütünsel bir görünürlük sağlar. Bu, manuel olarak analiz edilmesi imkansız olan veri selini yönetilebilir hale getirir.

Log Kaynakları

SIEM tarafından toplanan loglar temel olarak iki kategoriye ayrılır:

- **Ana Bilgisayar Merkezli (Host-Centric) Log Kaynakları:** Doğrudan bir ana bilgisayar (sunucu, Windows, Linux vb.) içinde veya onunla ilgili meydana gelen olayları yakalar.
 - **Örnekler:** Bir kullanıcının bir dosyaya erişmesi, kimlik doğrulama denemeleri, bir sürecin çalıştırılması, kayıt defteri (registry) değişiklikleri, PowerShell komutlarının yürütülmesi.
- **Ağ Merkezli (Network-Centric) Log Kaynakları:** Ana bilgisayarların birbirleriyle veya internetle iletişim kurduğu sırada oluşan olayları kaydeder.
 - **Örnekler:** Güvenlik duvarları (firewall), Saldırı Tespit/Önleme Sistemleri (IDS/IPS) ve yönlendiricilerden (router) gelen loglar. SSH bağlantıları, FTP üzerinden dosya erişimi, web trafiği, VPN bağlantıları ve ağ dosya paylaşımı gibi faaliyetleri içerir.

Tespit Kuralları

SIEM'in tehditleri tespit etme yeteneği, "tespit kuralları" olarak bilinen mantıksal ifadelerle dayanır. Bu kurallar, belirli senaryolar gerçekleştiğinde otomatik olarak uyarılar (alert) oluşturur.

- **Örnek Kurallar:**
 - Bir kullanıcı 10 saniye içinde beş kez başarısız oturum açma denemesi yaparsa, "Çok Sayıda Başarısız Oturum Açma Denemesi" uyarısı oluştur.
 - Giden ağ trafiği 25 MB'ı aşarsa, "Potansiyel Veri Sızdırma Girişimi" uyarısı oluştur.
 - Bir kullanıcı bir USB cihazı taktığında uyarı oluştur (şirket politikası gereği kısıtlıysa).

Örnek Platform: Splunk

Splunk, piyasadaki önde gelen SIEM çözümlerinden biridir ve ağ ile makine loglarını gerçek zamanlı olarak toplama, analiz etme ve ilişkilendirme yeteneğine sahiptir.

Splunk Bileşenleri:

Bileşen	Açıklama
Forwarder (İletici)	İzlenmesi amaçlanan uç noktalara kurulan hafif bir ajandır. Verileri toplar ve Splunk Indexer'a gönderir. Web sunucuları, Windows/Linux makineleri ve veritabanları gibi kaynaklardan veri toplayabilir.
Indexer (Dizinleyici)	Forwarder'lardan gelen verileri işleyen ana bileşendir. Veriyi ayırıştırır, alan-değer çiftlerine dönüştürerek normalleştirir ve olaylar (events) olarak depolar. Bu süreç, verinin aranmasını ve analiz edilmesini kolaylaştırır.

Search Head (Arama Başlığı)	Kullanıcıların dizinlenmiş logları aradığı arayüzdür. Aramalar, SPL (Search Processing Language) adı verilen güçlü bir sorgu dili kullanılarak yapılır. Arama sonuçları tablo, pasta grafiği ve sütun grafiği gibi görselleştirmelere dönüştürülebilir.
--	--

2. Elastic Stack (ELK)

Başlangıçta büyük veri kümelerini depolamak, aramak ve görselleştirmek için geliştirilen Elastic Stack (ELK), zamanla güvenlik operasyonları için de popüler hale gelmiş ve birçok SOC ekibi tarafından bir SIEM çözümü gibi kullanılmaktadır. Herhangi bir kaynaktan veri toplayan, depolayan, arayan ve görselleştiren açık kaynaklı bileşenler topluluğudur.

Bileşenleri ve Mimarisi

- **Elasticsearch:** JSON formatındaki belgeler için tam metin arama ve analitik motorudur. Verileri depolar, analiz eder, ilişkilendirir ve RESTful API aracılığıyla etkileşim sağlar. Veritabanı görevi görür.
- **Logstash:** Farklı kaynaklardan veri alan, bu veriyi filtreleyen veya normalleştiren ve ardından hedef bir konuma (Elasticsearch, Kibana vb.) gönderen bir veri işleme motorudur. Yapılandırması **Input**, **Filter** ve **Output** olmak üzere üç bölümden oluşur.
- **Beats:** Uç noktalardan Elasticsearch'e veri gönderen, "veri göndericileri" (data-shippers) olarak bilinen ana bilgisayar tabanlı, tek amaçlı ajanlardır. Örneğin, **Winlogbeat** Windows olay günlüklerini, **Packetbeat** ise ağ trafiği akışlarını toplar.
- **Kibana:** Elasticsearch ile birlikte çalışan, veri akışlarını gerçek zamanlı olarak analiz etmek, araştırmak ve görselleştirmek için kullanılan web tabanlı bir veri görselleştirme aracıdır.

Bileşenlerin Birlikte Çalışması:

1. **Beats**, uç noktalardan veri toplar.
2. **Logstash**, bu verileri alır, ayrıştırır/normalleştirir ve Elasticsearch'e depolar.
3. **Elasticsearch**, verileri aramak ve analiz etmek için bir veritabanı olarak işlev görür.
4. **Kibana**, Elasticsearch'te depolanan verileri görselleştirmek ve sunmak için kullanılır.

Kibana: Veri Keşfi ve Analizi

SOC analistlerinin zamanlarının çoğunu geçirdiği yer **Discover** sekmesidir. Bu sekme, alınan logları, arama çubuğunu ve normalleştirilmiş alanları gösterir.

- **Discover Sekmesi Özellikleri:**
 - **Logs:** Her satır, bir olaya ait bilgileri içeren tek bir logu gösterir.
 - **Fields Pane:** Loglardan ayrıştırılan alanların listelendiği sol panel.

- **Index Pattern:** Her log türü farklı bir dizin modelinde saklanır. Buradan ilgili dizin seçilir.
- **Search Bar:** Sonuçları daraltmak için sorguların ve filtrelerin girildiği alan.
- **Time Filter:** Sonuçları belirli bir zaman aralığına göre daraltma imkanı sunar.

Kibana Sorgu Dili (KQL)

Kibana Query Language (KQL), Elasticsearch'te alınan logları/belgeleri aramak için kullanılan bir sorgu dilidir. İki temel arama türü sunar:

1. **Free Text Search (Serbest Metin Arama):** Yalnızca metne dayalı arama yapar. Örneğin, **security** terimi arandığında, bu terimi içeren tüm belgeler, alan fark etmeksizin döndürülür.
2. **Field-based Search (Alan Tabanlı Arama):** Belirli bir alandaki değeri aramak için kullanılır. Sözdizimi **Alan: Değer** şeklindedir ve alan ile değer arasında iki nokta üst üste kullanılır.

3. Uç Nokta Tespiti ve Müdahale (EDR)

Endpoint Detection and Response (EDR), uç nokta seviyesinde gelişmiş tehditleri izlemek, tespit etmek ve bunlara müdahale etmek için tasarlanmış bir güvenlik çözümüdür. Özellikle uzaktan çalışmanın yaygınlaşmasıyla, kurumsal ağın çevre koruması dışında kalan cihazların güvenliğini sağlamak için kritik öneme sahiptir.

Antivirüs (AV) ile Karşılaştırma

EDR, geleneksel antivirüs yazılımlarından çok daha ileri düzeyde koruma sağlar.

- **Antivirüs (AV):** Bir havaalanındaki pasaport kontrolü gibidir. Gelen kişilerin pasaportlarını bilinen suçluların listesiyle eşleştirir ve bir eşleşme bulursa girişi engeller. Ancak, daha önce suçlu olarak tanımlanmamış profesyonel bir tehdidi içeri alabilir.
- **EDR:** Havaalanının içindeki güvenlik görevlileri ve kameralar gibidir. İçeri giren herkesin davranışlarını sürekli izler: "Kısıtlı alanlara yaklaşıyorlar mı?", "Şüpheli davranışlar sergiliyorlar mı?". AV'den kaçmayı başaran tehditleri davranışsal analiz ile tespit edebilir ve anında müdahale edebilir.

EDR'in Üç Temel Direği

1. **Visibility (Görünürlük):** EDR, süreç değişiklikleri, kayıt defteri modifikasyonları, kullanıcı eylemleri gibi uç noktalardan ayrıntılı veri toplayarak benzersiz bir görünürlük seviyesi sunar. Analistler, tüm süreç ağacını ve faaliyet zaman çizelgesini görebilir ve geçmiş verilere erişebilir.

2. **Detection (Tespit):** Hem imza tabanlı hem de davranış tabanlı (beklenmedik kullanıcı faaliyetleri gibi) tespit yeteneklerini birleştirir. Makine öğrenimi ile normal davranış çizgisinden sapmaları belirler, bellekte yaşayan dosyasız kötü amaçlı yazılımları tespit eder ve özel tehdit göstergelerini (IOC) kullanabilir.
3. **Response (Müdahale):** Analistlere, merkezi bir konsoldan herhangi bir uç noktada eylem yapma yetkisi verir. Bir uç noktayı tamamen izole etme, bir süreci sonlandırma veya dosyaları karantinaya alma gibi eylemler gerçekleştirilebilir.

Çalışma Prensipleri ve Telemetri

- **Ajanlar (Sensörler):** Uç noktalara dağıtılan ajanlar, tüm faaliyetleri izler ve bu bilgileri gerçek zamanlı olarak merkezi EDR konsoluna gönderir.
- **EDR Konsolu:** Ajanlardan gelen verilerin ilişkilendirildiği, makine öğrenimi algoritmaları ve tehdit istihbaratı ile analiz edildiği merkezi beyindir. Tespitler burada "uyarı" olarak ortaya çıkar.
- **Telemetri:** Ajanlar tarafından toplanan ve konsola gönderilen ham veridir. Bir uç noktanın "kara kutusu" olarak kabul edilir ve tespit ve araştırma için gerekli her şeyi içerir. Toplanan telemetri türleri arasında süreç yürütmeleri, ağ bağlantıları, komut satırı etkinlikleri, dosya/klasör değişiklikleri ve kayıt defteri modifikasyonları bulunur.

Gelişmiş Tespit ve Müdahale Yetenekleri

Yetenek Türü	Açıklama ve Örnekler
Tespit	Davranışsal Tespit: Bir dosyanın imzasından ziyade davranışını gözlemler. Örnek: <code>winword.exe</code> 'nin <code>powershell.exe</code> 'yi başlatması anormal bir ebeveyn-çocuk ilişkisi olarak işaretlenir. Anomali Tespiti: Uç noktanın temel davranışından sapan herhangi bir faaliyeti işaretler. IOC Eşleştirme: Faaliyetleri, bilinen tehdit göstergeleriyle (IOC) eşleştirir. MITRE ATT&CK Haritalama: Tespit edilen faaliyeti, saldırının hangi taktik ve tekniğine karşılık geldiğiyle eşleştirir. Örnek: Zamanlanmış görev oluşturma, "Kalıcılık" (Persistence) taktiğiyle eşleştirilir. Makine Öğrenimi Algoritmaları: Dosyasız saldırılar gibi karmaşık saldırı kalıplarını tespit eder.

Müdahale	Host Isolation (Ana Bilgisayarı İzole Etme): Yanal hareketi önlemek için virüslü bir uç noktanın ağ bağlantısını keser. Terminate Process (Süreci Sonlandırma): Kötü niyetli bir faaliyeti durdurmak için belirli bir süreci sonlandırır. Quarantine (Karantinaya Alma): Kötü niyetli bir dosyayı, çalıştırılmayacağı izole bir konuma taşır. Remote Access (Uzaktan Erişim): Analistlerin bir uç noktanın komut satırına uzaktan erişerek özel eylemler gerçekleştirmesine veya daha derin analiz yapmasına olanak tanır. Artefact Collection (Kanıt Toplama): Adli soruşturma için bellek dökümü, olay günlükleri veya kayıt defteri kovanları gibi önemli kanıtları uzaktan toplar.
-----------------	---

4. Güvenlik Orkestrasyonu, Otomasyonu ve Müdahale (SOAR)

Security Orchestration, Automation, and Response (SOAR), bir SOC'de kullanılan SIEM, EDR, güvenlik duvarı gibi çeşitli güvenlik araçlarını birleştiren bir platformdur. SOAR, SOC ekiplerinin karşılaştığı uyarı yorgunluğu, manuel süreçler, birbirinden kopuk araçlar ve ekipler arası iletişim zorlukları gibi sorunları çözmeyi hedefler.

Temel Yetenekleri

- Orchestration (Orkestrasyon):** Farklı satıcılara ait çeşitli güvenlik araçlarını tek bir SOAR arayüzünde birleştirir ve koordine eder. Bir uyarıyı araştırmak için gereken adımları tanımlayan "**Playbook**" adı verilen iş akışları oluşturur. Bu sayede analistlerin farklı araçlar arasında manuel olarak geçiş yapma ihtiyacını ortadan kaldırır.
- Automation (Otomasyon):** Playbook'larda tanımlanan adımları insan müdahalesi olmadan otomatik olarak çalıştırır. Bu, SOC analistlerinin zamanından önemli ölçüde tasarruf sağlar ve yüzlerce uyarıyı tükenmeden yönetmelerine olanak tanır.
- Response (Müdahale):** Farklı araçları kullanarak tek bir arayüzden eylem gerçekleştirme ve bu müdahaleleri otomatikleştirme yeteneği sunar.

SOAR'ın Pratik Uygulaması: VPN Kaba Kuvvet Saldırısı Senaryosu

Bir VPN kaba kuvvet saldırısı uyarısı alındığında, SOAR platformu otomatik olarak aşağıdaki adımları içeren bir playbook'u çalıştırabilir:

- SIEM'den uyarıyı alır.
- Kullanıcının geçmiş oturum açma bilgilerini kontrol etmek için SIEM'i otomatik olarak sorgular.
- Saldırgan IP'nin itibarını doğrulamak için Tehdit İstihbaratı (TI) platformlarını otomatik olarak kontrol eder.

4. IP kötü niyetliyse, güvenlik duvarında (firewall) IP'yi otomatik olarak engeller ve Kimlik ve Erişim Yönetimi (IAM) aracında kullanıcıyı devre dışı bırakır.
5. Son olarak, tüm ayrıntılarla birlikte bir olay takip sistemi (ticketing system) üzerinden otomatik olarak bir bilet açar.